

SahuAI-PRO-Lite / Manthan Agent

Unified Bug Report - 18 Confirmed Bugs

Compiled 24 September 2026 | 10 independent audits merged | 6 critical, 7 high, 4 medium, 1 low

This report merges the findings of ten independent AI audits of the codebase (Grok, ChatGPT, GLM, Qwen, Indus, Kimi, Gemini, DeepSeek, Meta AI and Claude Sonnet) into one deduplicated list. Only bugs that two or more auditors independently confirmed are included; single-audit findings were dropped as unverified. Two cross-confirmed findings - the hardcoded API keys in the public source and the missing PWA/APK assets - are excluded from this edition at the maintainer's request.

#	Bug	Severity	Confirmed by
1	toggleResearchStage() is called but never defined	CRITICAL	ChatGPT, GLM, Kimi
2	addCustomProvider() crashes on an undefined variable k	CRITICAL	Qwen, Kimi, Indus, DeepSeek
3	Agent Swarm silently never runs (setBusy is out of scope)	CRITICAL	Indus, Kimi
4	Custom providers are unusable even without the crash	CRITICAL	Kimi, DeepSeek
5	Z.ai endpoint typo: pass instead of paas	CRITICAL	Grok, ChatGPT
6	Deep Research always drops its 6th expert ('stage1' compared to a number)	CRITICAL	Indus, Kimi
7	Weak HTML sanitization enables XSS (no DOMPurify)	HIGH	Sonnet, Kimi, Meta, Qwen, Grok
8	Version identity is inconsistent across the app	HIGH	Grok, ChatGPT, GLM, Indus, Sonnet
9	Removed feature checkboxes are still read on save (flags forced false)	HIGH	ChatGPT, GLM, Indus, Sonnet, DeepSeek
10	Pin button breaks on quotes and apostrophes in answers	HIGH	Indus, Kimi
11	Escape key does not abort in-flight requests	HIGH	Indus, Qwen, Kimi, DeepSeek
12	init() is blocked by the full Pyodide download	HIGH	Indus, Kimi, DeepSeek, Meta
13	formatMarkdown corrupts code containing [n]	HIGH	Kimi, Indus
14	html2canvas-pro CDN script is misconfigured or dead	MEDIUM	Grok, Qwen, Gemini, Meta
15	eval() in the CALC tool can freeze the tab	MEDIUM	Sonnet, DeepSeek, Kimi
16	Dark-mode contrast failures	MEDIUM	ChatGPT, GLM, Kimi
17	Tailwind runtime CDN shipped in production	MEDIUM	Grok, Qwen, Meta
18	No DOCTYPE / pinch-zoom disabled	LOW	Grok, Indus, Meta

BUG 1 - [CRITICAL] toggleResearchStage() is called but never defined

Confirmed by: ChatGPT, GLM, Kimi

What happens

Every Deep Research phase header renders with an inline onclick="toggleResearchStage('...')" handler, but a full scan of the file finds zero definitions of the function - no function declaration, no window assignment anywhere. GLM traced the three call sites (L9714, L9823, L9920) and confirmed the bug is pre-existing: the original indexv0.1.html has the same 3 call sites with no definition.

Impact

Clicking any Deep Research phase header throws 'ReferenceError: toggleResearchStage is not defined' in the console. The collapse/expand affordance is completely dead - the UI silently ignores the click - and console noise accumulates with every click. The running research stream itself is not aborted, so the bug is masked.

Fix

Add the missing ~7-line function near the other research helpers: look up the 'content-' + stageId element, toggle its display, and toggle the 'collapsed' class on the stage. Apply the same fix to the original indexv0.1.html, where the bug originated.

BUG 2 - [CRITICAL] addCustomProvider() crashes on an undefined variable k

Confirmed by: Qwen, Kimi, Indus, DeepSeek

What happens

Inside addCustomProvider() (Indus: line 6517) the code calls localStorage.setItem(PROVIDERS[k].keyName, key), but there is no k in scope in that function - the other PROVIDERS[k] usages live inside forEach loops. Four auditors independently flagged the same line.

Impact

Clicking 'Add Provider' throws 'ReferenceError: k is not defined'. The provider is pushed into in-memory state but never persisted, the API key is never saved, the provider list is never re-rendered and the input fields are never cleared. After a page reload the half-added provider vanishes entirely.

Fix

Use the local provider object's keyName: localStorage.setItem(provider.keyName, key). The local object already carries the correct key name.

BUG 3 - [CRITICAL] Agent Swarm silently never runs (setBusy is out of scope)

Confirmed by: Indus, Kimi

What happens

_sahuRunAgentSwarm() (L12708) calls setBusy(...) at L12717, L12724 and L12731 and in its finally blocks, but setBusy is a const arrow function declared inside runSearchMode() (L11979). The top-level swarm function has no access to that closure variable, and no global setBusy exists.

Impact

Every swarm run throws 'ReferenceError: setBusy is not defined' immediately, before any worker is spawned. Both call sites swallow the error in try/catch, so the swarm silently never runs - the user just gets 'The swarm could not run this time.' At the second call site the raw sahu_agents directive text can remain in the final answer shown to the user.

Fix

Pass setBusy through the ctx object (it already carries addTrace), e.g. ctx.setBusy('...'), or hoist a global setBusy helper.

BUG 4 - [CRITICAL] Custom providers are unusable even without the crash

Confirmed by: Kimi, DeepSeek

What happens

renderProviderCheckboxes() only iterates the built-in PROVIDERS map, so a custom provider never appears in Settings (DeepSeek BUG-02/BUG-15: the key is never persisted or rendered, and customProviders are never merged into PROVIDERS). toggleProvider and saveSettings only know built-in keys, and toggleAllModels/setModelStage bail out for custom entries.

Impact

A custom provider can never be enabled, selected or used - the feature is effectively dead end-to-end, even after the addCustomProvider() crash (previous bug) is fixed.

Fix

Merge state.customProviders into the rendered provider list and make the enable/save/toggle paths aware of custom keys.

BUG 5 - [CRITICAL] Z.ai endpoint typo: pass instead of paas

Confirmed by: Grok, ChatGPT

What happens

The fireworks provider configuration points at api.z.ai/api/pass/v4/chat/completions; the official path is api.z.ai/api/paas/v4/chat/completions. Grok additionally notes the provider's identity is inconsistent: display name 'Zhipu AI', a Z.ai URL and the key name sahu_fireworks_key.

Impact

All requests through the fireworks provider fail with 404/bad URL before reaching the API.

Fix

Correct the path to paas/v4, and align the provider's display name, URL and key name so the identity is consistent.

BUG 6 - [CRITICAL] Deep Research always drops its 6th expert ('stage1' compared to a number)

Confirmed by: Indus, Kimi

What happens

In runDeepResearch() (L9926/9941/9976): const numExperts = stage.id <= 3 ? 6 : 5. But RESEARCH_STAGES (L5126) defines stage ids as strings ('stage1'...'stage5'), and 'stage1' coerces to NaN when compared to 3 - so the comparison is always false.

Impact

Stages 1-3 are configured for 6 experts each but always run only 5: the 6th expert (the Pros/Cons/Neutral specialist) never runs, the special role prompt guarded by stage.id <= 3 with idx === 5 is dead, and the header always says '5 Experts'.

Fix

Use ['stage1','stage2','stage3'].includes(stage.id), or give the stages numeric ids.

BUG 7 - [HIGH] Weak HTML sanitization enables XSS (no DOMPurify)

Confirmed by: Sonnet, Kimi, Meta, Qwen, Grok

What happens

Model output and user messages reach innerHTML with only partial sanitization. Sonnet ran the real formatMarkdown against payloads in a Node harness and verified the blacklist is bypassable: unquoted event handlers (an img tag with src=x/onerror), unquoted onload on svg tags, unquoted javascript: URLs, scr+script nesting that reassembles into a live script tag, meta refresh and base href (redirect/link hijack) and form action (phishing forms). Kimi adds that iframe, form, img and inline styles pass straight through. Sonnet also verified a one-click XSS through shared-conversation URL hashes (~L14082) whose payload can exfiltrate localStorage, and attribute injection through unescaped citation links (L9781/9786). Meta counted 103 innerHTML sinks; Qwen flagged the same pattern in loadChat().

Impact

Any provider, model or crafted link can inject arbitrary markup and script into the page. Because API keys live in localStorage on the same origin, one crafted shared link can steal every key a victim has saved.

Fix

Wrap the final HTML in DOMPurify.sanitize() at the point where formatMarkdown returns (forbid style, form, meta, base, iframe, object, embed), validate citation URLs (http/https only) and escape them, remove allow-same-origin from the canvas and preview iframes, and stop rendering shared content as raw HTML.

BUG 8 - [HIGH] Version identity is inconsistent across the app

Confirmed by: Grok, ChatGPT, GLM, Indus, Sonnet

What happens

The title and meta description say v7.8, the sidebar and docs modal say 'Version 5.0', the main script banner says v5.0, and code comments go up to v7.9.12. GLM counted 43 references to v7.9.x including six substantive v7.9.12 change markers behind the v7.8 nameplate.

Impact

Users and developers cannot tell what version is running; bug reports, debugging, release tracking and cache diagnosis are all unreliable, and behavior introduced in v7.9.12 is attributed to v7.8.

Fix

Introduce a single APP_VERSION constant and template every surface (title, meta, sidebar, docs, boot logs, toast, document.title) from it.

BUG 9 - [HIGH] Removed feature checkboxes are still read on save (flags forced false)

Confirmed by: ChatGPT, GLM, Indus, Sonnet, DeepSeek

What happens

saveSettings() still reads about 30 element IDs that no longer exist in the markup, with a '?? false' fallback: neuralConsensusCheck, debateModeCheck, adaptiveReasoningCheck, agentSwarmCheck, constitutionalSafetyCheck, the three safety-model checkboxes, singleModelSelect, asrModelSelect, aggregationStyle, thinkingBudget, stageSelector, autoFallback, promptRefinerCheck and more (GLM: L6234-6247; Sonnet: L7401-7451).

Impact

Five advertised features (Agent Swarm, Neural Consensus, Debate Mode, Adaptive Reasoning, Constitutional Safety) can never be enabled - the flags are persisted false forever. Saving settings silently disables all safety models; autoFallback and promptRefiner are forced true so users cannot turn them off; voiceConfig resets to defaults on every save; and runDebateMode() is unreachable (DeepSeek BUG-11).

Fix

Guard every read with if (el) so a missing control leaves the saved value alone, and delete the dead reads for features that are intentionally retired.

BUG 10 - [HIGH] Pin button breaks on quotes and apostrophes in answers

Confirmed by: Indus, Kimi

What happens

The pin/thumbtack button (Indus: L9649) interpolates escapeHtml(res.content.substring(0, 100)) directly into an inline onclick attribute. escapeHtml escapes &, < and > but not single quotes, double quotes or newlines.

Impact

Any research answer containing don't, it's or a line break within its first 100 characters produces a JS syntax error inside the onclick attribute - the pin button silently does nothing, and the quote handling opens a small injection window.

Fix

Escape ' and " as well, or attach the handler via addEventListener with the text held in a data attribute or closure instead of an inline attribute.

BUG 11 - [HIGH] Escape key does not abort in-flight requests

Confirmed by: Indus, Qwen, Kimi, DeepSeek

What happens

handleKeyDown() (~L12970) handles the Escape key by only setting state.isProcessing = false. It never touches window.activeAbortControllers and never re-enables buttons - inconsistent with the Stop button path in handleDynamicAction(), which aborts all AbortControllers.

Impact

Streams keep downloading in the background and burn tokens after the user pressed Escape; the UI just pretends it stopped. Kimi adds that the simulated-streaming loop for non-streaming providers is not abort-aware either.

Fix

On Escape, call the same abort logic the Stop button uses: abort every active AbortController and re-enable the input controls.

BUG 12 - [HIGH] init() is blocked by the full Pyodide download

Confirmed by: Indus, Kimi, DeepSeek, Meta

What happens

init() (~L13009) awaits initPyodide() before calling handleSharedConversation() and setupKeyboardShortcuts(), even though the Pyodide runtime is only needed for the CALC tool. Meta measured the blocking payload at ~120 MB with LCP pushed to about 7 seconds.

Impact

Opening a shared-conversation link renders nothing until the entire WASM runtime has downloaded and booted - tens of seconds of blank screen on slow connections - and keyboard shortcuts are unavailable during that window. The v6.4 code worker downloads its own copy anyway.

Fix

Make initPyodide() fire-and-forget (or lazy-load it on the first Python/CALC run) and run handleSharedConversation() synchronously.

BUG 13 - [HIGH] formatMarkdown corrupts code containing [n]

Confirmed by: Kimi, Indus

What happens

Citation replacement (turning [1] into a citation link) runs before code fences are extracted from the markdown, and the bold/inline-code passes run after. Indus reports the same defect as: citation rewriting applies inside code blocks.

Impact

Any array indexing (arr[0]) or bracketed number inside a code block becomes citation HTML: the displayed code is corrupted, and the Copy/Run/Canvas actions receive the corrupted text.

Fix

Extract fenced code blocks before the citation-rewriting pass and restore them afterwards - reorder the pipeline so code content is never touched.

BUG 14 - [MEDIUM] html2canvas-pro CDN script is misconfigured or dead

Confirmed by: Grok, Qwen, Gemini, Meta

What happens

The script tag points at the bare package name on jsDelivr. Qwen: it loads the ESM build as a classic script and throws "SyntaxError: Unexpected token 'export'". Meta: the URL 404s in the current build. Gemini: the version is unpinned, so upstream breakages flow straight in. Grok: it is never referenced by application JS at all - a dead dependency either way.

Impact

The library either fails to load or does nothing, and the unpinned import is a standing breakage risk.

Fix

Pin the URL to `html2canvas-pro@1.5.8/dist/html2canvas-pro.min.js` - or remove the dependency entirely, since no application code calls it.

BUG 15 - [MEDIUM] `eval()` in the CALC tool can freeze the tab

Confirmed by: Sonnet, DeepSeek, Kimi

What happens

The CALC branch (~L9414, DeepSeek BUG-05) evaluates expressions with `eval()`. Its character filter blocks letters but allows `*`, so exponent chains like `9**9**9` evaluate to Infinity or hang. Kimi adds that `executeTool` itself is never called and strips letters so `sqrt(4)` always yields 'CALC ERROR'.

Impact

A model-triggered CALC call can freeze the tab; the whole tool path is dead or dangerous.

Fix

Replace `eval` with a small expression parser (or a vetted math library) and cap exponent size; fix or remove the dead `executeTool` path.

BUG 16 - [MEDIUM] Dark-mode contrast failures

Confirmed by: ChatGPT, GLM, Kimi

What happens

Placeholders use `--text-muted: #5d6879` in dark mode, measured at 3.24:1 against the composer surface `#11151d` - below the WCAG AA 4.5:1 requirement (light theme passes; dark only). Kimi separately found the dark-mode welcome screen is black-on-black: the eagle 'Manthan' span and title use inline `color:#000 !important`, which beats the `.dark-mode` stylesheet rule.

Impact

Composer and history-search hints are unreadably faint in dark mode for low-vision users or dim screens; the welcome title is effectively invisible in dark mode.

Fix

Set `--text-muted` to `#7c8899` (5.08:1) in dark mode, and remove the inline `!important` colors so the dark theme rules can apply.

BUG 17 - [MEDIUM] Tailwind runtime CDN shipped in production

Confirmed by: Grok, Qwen, Meta

What happens

The page loads the 300 KB Tailwind Play CDN development runtime (Meta), and Grok found Tailwind is actually loaded twice - the runtime CDN plus a large precompiled block before the closing head tag.

Impact

Extra download, possible class conflicts, slower first paint and FOUC.

Fix

Compile Tailwind with the CLI into a minified `output.css`, drop the runtime CDN, and keep only the precompiled block (if it is complete).

BUG 18 - [LOW] No DOCTYPE / pinch-zoom disabled

Confirmed by: Grok, Indus, Meta

What happens

Line 1 starts directly with the `<html>` tag, so browsers may enter quirks mode with inconsistent layout behavior. The viewport meta sets `maximum-scale=1.0` and `user-scalable=no`, which blocks pinch-zoom - a WCAG accessibility failure on mobile.

Impact

Inconsistent cross-browser rendering from quirks mode; mobile users cannot zoom.

Fix

Add `<!DOCTYPE html>` at line 1 and remove the zoom restrictions from the viewport meta.

Sources

Grok (GrokBug.pdf), ChatGPT (GPTBUG.pdf), GLM (GLMBUG.md), Qwen (Qwen_bug.pages), Indus (IndusBug.md), Kimi (KimiBug.pages), Gemini (GemBug.md), DeepSeek (DSHBUG.pages), Meta AI (MetaBUG.PNG), Claude Sonnet (SonnetBug.md).